

Report di Analisi Forense di Rete: Rilevamento Attività di Port Scanning

Analista: Mirko Imbrogno

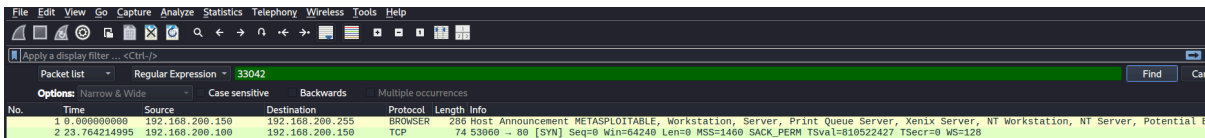
Oggetto: Analisi del file di cattura `Cattura_U3_W1_L3.pcapng`

Strumento utilizzato: Wireshark

1. Introduzione e Identificazione degli Attori

L'attività di analisi è iniziata con l'apertura del file di log su Wireshark. Il primo obiettivo è stato identificare gli host coinvolti nella comunicazione per stabilire il perimetro dell'indagine.

Dall'analisi dei primi pacchetti, ho immediatamente identificato la macchina vittima. L'indirizzo IP **192.168.200.150** invia un pacchetto di protocollo *BROWSER* contenente un "Host Announcement".

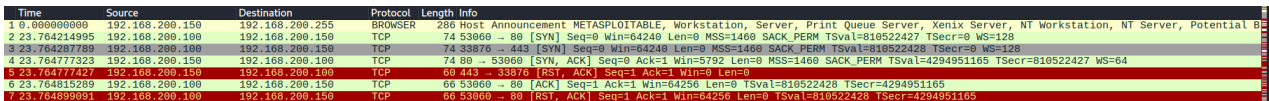


No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000000	192.168.200.150	192.168.200.255	BROWSER	286	Host Announcement METASPLOITABLE, Workstation, Server, Print Queue Server, Xenix Server, NT Workstation, NT Server, Potential B
2	23.764214995	192.168.200.100	192.168.200.150	TCP	74	53960 -> 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810522427 TSecr=0 WS=128

- **Dettaglio rilevato:** Il nome della macchina è esplicitamente dichiarato come **METASPLOITABLE**.
- **Deduzione:** Essendo Metasploitable una macchina virtuale intenzionalmente vulnerabile progettata per test di sicurezza, ho confermato che **192.168.200.150** è il **Target (Vittima)**.

2. Analisi del Traffico e Rilevamento Anomalie

Successivamente, ho analizzato il flusso dei pacchetti TCP per individuare attività sospette. Osservando la sequenza temporale e le conversazioni, ho notato un comportamento anomalo proveniente dall'host **192.168.200.100**.



Time	Source	Destination	Protocol	Length	Info
1	0.000000000	192.168.200.150	192.168.200.255	BROWSER	286 Host Announcement METASPLOITABLE, Workstation, Server, Print Queue Server, Xenix Server, NT Workstation, NT Server, Potential B
2	23.764214995	192.168.200.100	192.168.200.150	TCP	74 53960 -> 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810522427 TSecr=0 WS=128
3	23.764297789	192.168.200.100	192.168.200.150	TCP	74 53976 -> 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810522428 TSecr=0 WS=128
4	23.764777323	192.168.200.150	192.168.200.100	TCP	74 80 -> 53960 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294951165 TSecr=810522427 WS=64
5	23.764777427	192.168.200.150	192.168.200.100	TCP	60 443 -> 33870 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
6	23.764813289	192.168.200.100	192.168.200.150	TCP	66 53960 -> 80 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810522428 TSecr=4294951165
7	23.764899991	192.168.200.100	192.168.200.150	TCP	66 53960 -> 80 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810522428 TSecr=4294951165

Osservazioni sul traffico:

- L'host **192.168.200.100** (sconosciuto/attaccante) invia una raffica di pacchetti con flag **[SYN]** verso molteplici porte del target **192.168.200.150**.
- In diversi casi (es. righe 12, 19, 24 del log), ho osservato il completamento del **Three-Way Handshake**:
 1. Attaccante invia **[SYN]**.
 2. Vittima risponde **[SYN, ACK]** (porta aperta).
 3. Attaccante conclude con **[ACK]**.
- Per le porte chiuse, la vittima risponde immediatamente con **[RST, ACK]**.

400	36.795726078	192.168.200.100	192.168.200.150	TCP	74	44560 → 731	[SYN]	Seq=0	Win=64240	Len=0	MSS=1460	SACK_PERM	TSval=810535459	TSecr=0	WS=128
401	36.795806619	192.168.200.100	192.168.200.150	TCP	74	39176 → 405	[SYN]	Seq=0	Win=64240	Len=0	MSS=1460	SACK_PERM	TSval=810535459	TSecr=0	WS=128
402	36.795886644	192.168.200.100	192.168.200.150	TCP	74	37760 → 318	[SYN]	Seq=0	Win=64240	Len=0	MSS=1460	SACK_PERM	TSval=810535459	TSecr=0	WS=128
403	36.795966648	192.168.200.100	192.168.200.150	TCP	74	40454 → 321	[SYN]	Seq=0	Win=64240	Len=0	MSS=1460	SACK_PERM	TSval=810535459	TSecr=0	WS=128
404	36.796043782	192.168.200.100	192.168.200.150	TCP	74	54344 → 909	[SYN]	Seq=0	Win=64240	Len=0	MSS=1460	SACK_PERM	TSval=810535459	TSecr=0	WS=128
405	36.796136358	192.168.200.100	192.168.200.150	TCP	74	35948 → 188	[SYN]	Seq=0	Win=64240	Len=0	MSS=1460	SACK_PERM	TSval=810535459	TSecr=0	WS=128

412	36.796569265	192.168.200.150	192.168.200.100	TCP	60	731 → 44560	[RST, ACK]	Seq=1	Ack=1	Win=0	Len=0
413	36.796569306	192.168.200.150	192.168.200.100	TCP	60	405 → 39176	[RST, ACK]	Seq=1	Ack=1	Win=0	Len=0
414	36.796569347	192.168.200.150	192.168.200.100	TCP	60	318 → 37760	[RST, ACK]	Seq=1	Ack=1	Win=0	Len=0
415	36.796569388	192.168.200.150	192.168.200.100	TCP	60	321 → 40454	[RST, ACK]	Seq=1	Ack=1	Win=0	Len=0
416	36.796569428	192.168.200.150	192.168.200.100	TCP	60	909 → 54344	[RST, ACK]	Seq=1	Ack=1	Win=0	Len=0
417	36.796569469	192.168.200.150	192.168.200.100	TCP	60	188 → 35948	[RST, ACK]	Seq=1	Ack=1	Win=0	Len=0

Deduzione del Tipo di Attacco: La velocità delle richieste e il completamento della connessione TCP mi hanno permesso di classificare l'attività non come traffico utente legittimo, ma come una **scansione Nmap di tipo TCP Connect Scan (nmap -sT)**. A differenza di una scansione **STEALTH** (SYN Scan), qui l'attaccante stabilisce una connessione completa con il servizio per verificarne l'attività.

3. Risultati di Threat Intelligence

A. Identificazione e Analisi degli IOC (Indicatori di Compromissione)

Gli IOC rilevati che confermano un attacco in fase di *Information Gathering* sono:

- **IP Attaccante:** **192.168.200.100**.
- **IP Vittima:** **192.168.200.150** (Hostname: METASPLOITABLE).
- **Pattern di Traffico:** Elevato volume di pacchetti **TCP SYN** sequenziali in un arco temporale ridottissimo (millisecondi), tipico di strumenti automatizzati di scanning.
- **Completezza della Connessione:** La presenza di handshake completi (**SYN -> SYN/ACK -> ACK**) su porte critiche indica che la mappatura dei servizi ha avuto successo e l'attaccante conosce ora quali porte sono aperte.

B. Ipotesi sui Vettori di Attacco

In base alle risposte positive (porte aperte) ottenute dalla scansione, i potenziali vettori di attacco identificati sono:

1. **Porta 23 (Telnet):** La scansione ha rilevato questa porta aperta. Telnet è un protocollo obsoleto che trasmette credenziali e comandi in chiaro. Un attaccante può facilmente intercettare il traffico (Sniffing) o tentare un attacco Brute Force per ottenere accesso amministrativo.
2. **Porta 80 (HTTP):** La presenza di un web server attivo espone la macchina a vulnerabilità web classiche (SQL Injection, XSS, RFI), specialmente su una macchina "Metasploitable" che ospita di default applicazioni web non sicure (es. DVWA).
3. **Porte Alte (fino a 60640):** La scansione si è estesa fino alle porte alte, suggerendo la ricerca di servizi non standard o backdoor precedentemente installate (es. una shell di root in ascolto su una porta effimera).

C. Azioni Consigliate (Mitigazione e Prevenzione)

Per ridurre l'impatto dell'attacco attuale ed evitarne di futuri, si raccomandano le seguenti azioni correttive:

Azioni di Mitigazione Immediata (Contenimento):

- **Blocco IP:** Configurare il firewall perimetrale o locale (es. `iptables`) per dropare tutto il traffico proveniente dall'IP `192.168.200.100`.
- **Stop dei Servizi Critici:** Arrestare immediatamente i servizi non necessari e insicuri identificati dalla scansione, in particolare il demone **Telnet**.

Azioni di Prevenzione Futura (Hardening):

- **Transizione a Protocolli Sicuri:** Sostituire definitivamente Telnet con **SSH (Porta 22)**, configurandolo per accettare solo autenticazione tramite chiavi crittografiche (es. RSA) e disabilitando l'accesso root via password.
- **Cifratura Web:** Migrare i servizi web dalla porta 80 (HTTP) alla 443 (HTTPS) implementando certificati SSL/TLS validi.
- **Implementazione IDS/IPS:** Installare un sistema di *Intrusion Detection* (come Snort o Suricata) configurato per rilevare pattern di "Port Scanning" e bloccare automaticamente la sorgente (Ban temporaneo) prima che l'enumerazione sia completa.
- **Network Segmentation:** Isolare la macchina vulnerabile in una VLAN dedicata (DMZ) per impedire movimenti laterali verso il resto della rete aziendale.